

Security Maturity Assessment

Acme Corp

Prepared by Jane Doe

Month YYYY



INSERT CUSTOMER LOGO

Acme Corp – Executive Summary

Acme Corp have undergone a Security Maturity Assessment completed by Planet IT. This comprehensive assessment of the current security implementation of Acme Corp focused on assessing the security maturity of the systems, solutions and culture in place at Acme Corp. Namely focusing in the following areas:

- **Identity & Access Management (IAM):** An evaluation of authentication controls, MFA enforcement, and alignment with zero-trust principles to protect user credentials.
- **Endpoint Protection:** The posture of device-level security, malware defence, and the restriction of local administrator privileges across the estate.
- **Network & Perimeter Security:** An assessment of firewall architectures, network segmentation, and secure remote access controls for physical and virtual locations.
- **Email & Collaboration Security:** Defences against phishing, business email compromise (BEC), and malicious payloads within core productivity suites (e.g., Microsoft 365).
- **Cloud & Infrastructure Security:** The security configuration and workload protection mechanisms applied to public cloud environments and on-premises server infrastructure.
- **Security Monitoring & Response (MDR/SOC):** The organisation's capability to actively detect, investigate, and remediate threats on a 24/7 basis using cross-domain telemetry.
- **Security Validation & Testing:** The frequency and efficacy of proactive offensive testing, including vulnerability scanning and internal/external penetration testing.
- **Security Culture & Awareness:** An analysis of human-centric risk, evaluating the maturity of user coaching, phishing simulations, and general security behaviour.
- **Governance, Risk & Compliance (GRC):** The strategic alignment of current controls with target compliance frameworks (e.g., ISO 27001, Cyber Essentials) and the overarching protection of critical business assets.

The report provides an overview of the current estimated security maturity in place at Acme Corp, identifies potential risks and issues, and recommends best practices and remediation actions to improve the security posture and culture at Acme Corp.

The main findings and recommendations of the report are:

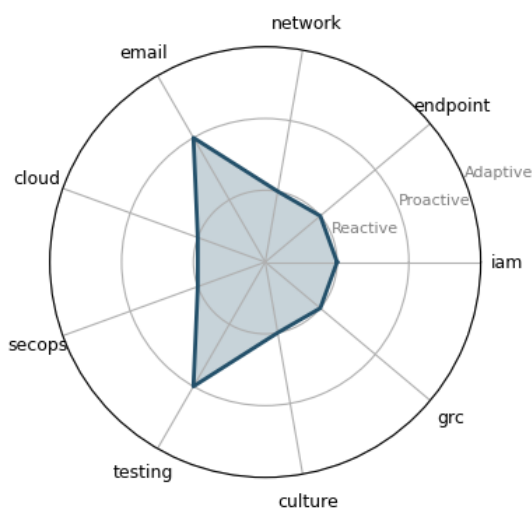
Current Posture Overview

Acme Corp, as a technology firm handling sensitive patient records, operates in a high-risk environment where the consequences of a breach would be catastrophic. The lack of universally enforced MFA, manual patch management, and reliance on legacy VPN for remote access are critical vulnerabilities. These gaps significantly elevate the risk of credential theft, ransomware, and data exfiltration, particularly given the value of the patient records database to threat actors. Furthermore, the absence of SaaS backups for M365 and a formal incident response plan leaves Acme Corp unprepared to recover effectively from an attack, with a downtime tolerance of 12-24 hours at severe risk of being exceeded. The financial and reputational impacts of such an event could include regulatory fines under GDPR and a loss of client trust, jeopardising long-term business viability.

The strategic roadmap for Acme Corp must begin with foundational hygiene improvements, such as enforcing MFA universally, automating patch management, and implementing a robust backup solution. This will stabilise the environment and align with Cyber Essentials compliance. The next phase should introduce active managed defence capabilities like Adlumin MDR to provide 24/7 threat detection and response, complemented by security awareness training to address human risk factors. Finally, the roadmap should culminate in adaptive governance measures, including the adoption of Zero Trust Architecture and automated disaster recovery, ensuring resilience against

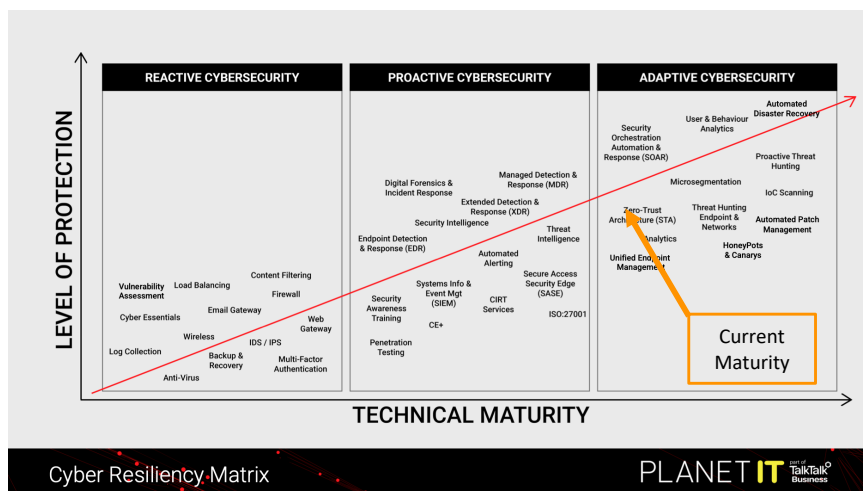
evolving threats. These efforts will not only reduce risk but also position Acme Corp as a security-conscious organisation capable of maintaining regulatory compliance and protecting its critical assets.

Current domain alignment



Cyber Maturity Matrix Alignment

Pillar 1: Reactive Cybersecurity



Compliance and Framework Alignment

Standard: ISO 27001 Remediation Plans:

- **Gap:** Develop and implement a formal incident response plan.
 - **Actions:**
 - Conduct workshops to define roles and responsibilities.
 - Draft incident playbooks for likely scenarios.
 - Establish a quarterly tabletop testing schedule.
 - **Owner:** CISO
 - **Due By:** 2024-03-31
- **Gap:** Automate patch management processes.
 - **Actions:**
 - Deploy N-able N-central for automated patching.
 - Schedule regular patch audits to ensure compliance.
 - Integrate patch management with vulnerability scanning tools.
 - **Owner:** IT Operations Manager
 - **Due By:** 2024-01-15 **Standard:** Cyber Essentials **Remediation Plans:**
- **Gap:** Enforce MFA for all users.
 - **Actions:**
 - Configure conditional access policies in Microsoft Entra ID.
 - Roll out MFA training and support to staff.
 - Monitor and enforce compliance through regular audits.
 - **Owner:** IT Security Team
 - **Due By:** 2024-02-28
- **Gap:** Replace legacy VPN with a Zero Trust solution.
 - **Actions:**
 - Deploy Sophos ZTNA for secure remote access.
 - Decommission legacy VPN infrastructure.
 - Train users on the new access protocols.
 - **Owner:** Network Administrator
 - **Due By:** 2024-04-15

The Cost of Inaction

Neglecting to address the foundational security gaps at Acme Corp would expose the organisation to significant operational, financial, and reputational risks. The reliance on manual patch management and limited MFA enforcement creates a high likelihood of compromise through phishing attacks or exploitation of unpatched vulnerabilities. Given the high value of the patient records database, this could result in severe data breaches, regulatory fines under GDPR, and potential legal action. The absence of SaaS backups means that any ransomware attack could lead to irreversible data loss, while the lack of a formal incident response plan would exacerbate recovery times, potentially pushing downtime well beyond the stated 24-hour tolerance. Additionally, without cyber insurance, Acme Corp would bear the full financial burden of such incidents, including remediation costs, lost revenue, and reputational damage that could deter future business opportunities. Investing in a structured cybersecurity programme is not merely a compliance exercise but a critical business continuity imperative.

Estimated financial impact exceeds £750,000, encompassing fines, operational downtime, and reputational damage.

The technology sector, particularly those handling sensitive data like patient records, is a prime target for ransomware groups and Advanced Persistent Threat (APT) actors. Groups such as Conti and

LockBit have a history of targeting organisations with high-value data, leveraging phishing campaigns and exploiting unpatched vulnerabilities to gain access. The reliance on legacy VPNs and limited MFA enforcement makes Acme Corp particularly susceptible to credential theft and lateral movement within the network. Additionally, the absence of SaaS backups heightens the risk of irrecoverable data loss in ransomware scenarios. These factors underscore the urgency of implementing robust access controls, automated patching, and comprehensive threat detection capabilities.

Overview of Current Environment

Organisational Profile	Details
Industry	Technology
Headcount	500
Endpoints / Servers	600 / 50
Operating Systems	Windows 10/11, Windows Server
Cloud Infrastructure	AWS
Microsoft Licensing	M365 Business Premium
In-House Security Coverage	No
Target Compliance	ISO 27001, Cyber Essentials
Crown Jewels	Patient Records Database

Current Technology	Details
MDR / SOC Provider	None
Endpoint Security	Trend Micro
Endpoint Technology	EDR Deployed (Endpoint Detection & Response)
Network Firewall	Fortinet
Identity & Access	Microsoft Entra ID (Azure AD)
Email Security	Mimecast
Security Culture	Pillar 1: Reactive Culture - Currently developing baseline awareness. Focus should be placed on universally enforcing MFA and restricting local administrator privileges.
Internal SOC Team	No
Penetration Testing	Annual
Vulnerability Scanning	Monthly Authenticated

Risk, Compliance and Posture	Details
Backups Structure	On-Premise Only
SaaS Backups	None (Relying on Microsoft/Google)
Remote Access Strategy	Legacy VPN (Client-based)
Incident Response Readiness	No Formal Plan
MFA Status	Privileged Accounts Only
Patching Strategy	Manual / Ad-hoc
Cyber Insurance Status	None
Outage Tolerance	12-24 Hours

Detailed Assessment

Domain: Endpoint & Server Security

Field	Details
Current Maturity	Pillar 1: Reactive Cybersecurity
Technical Analysis	Acme Corp currently relies on Trend Micro's EDR for endpoint security, which provides basic detection and response capabilities. However, the lack of automated patch management significantly undermines the efficacy of the EDR solution, leaving endpoints vulnerable to known exploits. Manual patching processes are inherently slow and error-prone, creating a window of opportunity for adversaries to exploit unpatched vulnerabilities. Furthermore, the absence of advanced threat hunting capabilities means that sophisticated threats could linger undetected within the environment. This reactive posture is insufficient given the criticality of the patient records database, which requires robust defence mechanisms to ensure its integrity and confidentiality.
Business Impact & Risk	The combination of manual patch management and limited endpoint capabilities creates a high likelihood of compromise through known vulnerabilities. An attacker exploiting these gaps could gain initial access, escalate privileges, and move laterally within the network, potentially exfiltrating sensitive patient records. Such an incident would not only result in regulatory penalties under GDPR but also erode client trust, leading to reputational damage and potential loss of business. The operational impact of a breach could exceed Acme Corp's stated RTO, further compounding financial losses.
Critical Gaps	- Manual patch management - Lack of advanced threat hunting capabilities
Zero-Cost Quick Wins	- Enforce strict patching timelines and prioritise critical updates. - Disable local administrator privileges to limit lateral movement. - Enable built-in OS-level security features such as Windows Defender Credential Guard.
Recommended Solutions	N-able N-central
Strategic Remediation Rationale	Automating patch management through N-able N-central will close the critical gap of unpatched vulnerabilities, significantly reducing the attack surface. This tool's ability to schedule and enforce updates ensures that endpoints remain secure against known exploits. By integrating patch management with existing EDR capabilities, Acme Corp can create a cohesive defence strategy that not only prevents attacks but also detects and responds to active threats. This approach aligns with best practices for endpoint security and supports compliance with Cyber Essentials requirements.

Partnership Recommendations	Planet IT will deploy and configure N-able N-central to automate patch management processes and integrate them with existing endpoint security tools. Acme Corp's internal IT team will be responsible for monitoring patch compliance and ensuring that all endpoints are enrolled in the solution.
------------------------------------	--

Domain: Email & Data Protection

Field	Details
Current Maturity	Pillar 2: Proactive Cybersecurity
Technical Analysis	Acme Corp utilises Mimecast for email security, which provides robust protection against phishing, malware, and spam. However, the lack of SaaS backups for M365 poses a significant risk to data availability and integrity. Relying solely on Microsoft's built-in recovery options is insufficient, particularly in ransomware scenarios where data could be encrypted or deleted. The absence of immutable backups means that Acme Corp is at risk of permanent data loss, which could have severe operational and regulatory consequences. While the current email security measures are effective, the overall data protection strategy is undermined by this critical gap.
Business Impact & Risk	Without SaaS backups, Acme Corp faces a high risk of data loss in ransomware attacks or accidental deletions. The patient records database, which is integral to the organisation's operations, could be rendered inaccessible, leading to significant downtime and regulatory non-compliance. This vulnerability not only jeopardises operational continuity but also exposes Acme Corp to potential fines under GDPR and loss of client trust. The operational impact of such an incident would likely exceed the stated RTO, further magnifying financial and reputational damages.
Critical Gaps	• No SaaS backups for M365 • Lack of immutable backup solutions
Zero-Cost Quick Wins	• Enable retention policies in M365 to provide basic data recovery options. • Implement access controls to restrict data deletion permissions. • Educate staff on secure email practices to reduce the risk of phishing.
Recommended Solutions	• N-able Cove Data Protection
Strategic Remediation Rationale	Implementing N-able Cove Data Protection will address the critical gap of lacking SaaS backups by providing a robust, cloud-first backup solution. Its immutable backup capabilities ensure that data remains recoverable even in ransomware scenarios, aligning with best practices for data protection. By integrating this solution with existing email security measures, Acme Corp can create a comprehensive data protection strategy that safeguards critical assets and supports regulatory compliance.

Partnership Recommendations	Planet IT will deploy and configure N-able Cove Data Protection to ensure automated backups and data integrity. Acme Corp will be responsible for defining backup policies and ensuring that critical data sources are included in the backup scope.
------------------------------------	--

Domain: Identity & Access Management (IAM)

Field	Details
Current Maturity	Pillar 1: Reactive Cybersecurity
Technical Analysis	Acme Corp's current IAM capabilities are limited to enforcing MFA for privileged accounts, leaving standard user accounts vulnerable to credential theft. This gap significantly increases the risk of unauthorised access, particularly through phishing attacks. While Microsoft Entra ID provides a strong foundation for managing identities, the lack of universal MFA enforcement undermines its effectiveness. Furthermore, the absence of conditional access policies means that access is not adequately restricted based on user behaviour or device compliance. These weaknesses make it easier for threat actors to gain unauthorised access to sensitive systems, including the patient records database.
Business Impact & Risk	The absence of universal MFA enforcement and conditional access policies creates a high likelihood of unauthorised access to sensitive systems. Credential theft through phishing or brute force attacks could allow adversaries to exfiltrate patient records, resulting in regulatory fines under GDPR and significant reputational damage. The operational impact of such an incident would likely exceed the stated RTO, as recovery efforts would be complicated by the lack of robust access controls. This gap also increases the risk of lateral movement within the network, further amplifying potential damages.
Critical Gaps	• No universal MFA enforcement • Lack of conditional access policies
Zero-Cost Quick Wins	• Enable MFA for all user accounts through Microsoft Entra ID. • Define and implement conditional access policies based on user roles. • Regularly review and audit access logs for anomalies.
Recommended Solutions	• Microsoft 365 Business Premium / E5
Strategic Remediation Rationale	Upgrading to Microsoft 365 Business Premium or E5 will enable the enforcement of universal MFA and the implementation of conditional access policies. These measures will significantly enhance identity security by ensuring that access is granted based on user behaviour and device compliance. By leveraging Microsoft's built-in tools, Acme Corp can create a more secure and resilient IAM framework that aligns with best practices and compliance requirements.

Partnership Recommendations	Planet IT will assist in configuring Microsoft Entra ID to enforce MFA and implement conditional access policies. Acme Corp will be responsible for ensuring user compliance with these policies and regularly reviewing access logs.
------------------------------------	---

Domain: Network & Cloud Perimeter

Field	Details
Current Maturity	Pillar 1: Reactive Cybersecurity
Technical Analysis	Acme Corp currently relies on a legacy VPN for remote access, which is both outdated and insufficient for securing modern hybrid work environments. Legacy VPNs are vulnerable to credential theft and lack the granular access controls required to enforce Zero Trust principles. While the Fortinet firewall provides a strong perimeter defence, its effectiveness is limited by the lack of integration with identity-based access controls. The absence of a modern remote access solution not only increases the risk of unauthorised access but also complicates the implementation of advanced security measures like micro-segmentation.
Business Impact & Risk	The reliance on a legacy VPN for remote access poses a significant risk to Acme Corp's network security. Credential theft or exploitation of VPN vulnerabilities could allow adversaries to bypass perimeter defences and gain unauthorised access to sensitive systems. This risk is particularly concerning given the criticality of the patient records database. A breach of this nature would result in regulatory fines, reputational damage, and operational disruptions that exceed the stated RTO. The lack of a modern remote access solution also limits the organisation's ability to adopt Zero Trust principles, further exposing the network to potential attacks.
Critical Gaps	• Reliance on legacy VPN • Lack of Zero Trust principles
Zero-Cost Quick Wins	• Restrict VPN access to specific IP ranges. • Enable multi-factor authentication for VPN logins. • Monitor VPN logs for anomalous access patterns.
Recommended Solutions	• Sophos ZTNA (Zero Trust Network Access)
Strategic Remediation Rationale	Deploying Sophos ZTNA will replace the legacy VPN with a modern, identity-driven remote access solution. This will enable Acme Corp to enforce granular access controls and adopt Zero Trust principles, significantly reducing the risk of unauthorised access. By integrating with existing identity management systems, Sophos ZTNA ensures that access is granted based on user behaviour and device compliance, aligning with best practices for network security.
Partnership Recommendations	Planet IT will deploy and configure Sophos ZTNA to replace the legacy VPN. Acme Corp will be responsible for training users on the

	new access protocols and ensuring compliance with access policies.
--	--

Domain: Security Operations & Response (SecOps)

Field	Details
Current Maturity	Pillar 1: Reactive Cybersecurity
Technical Analysis	Acme Corp currently lacks a dedicated MDR solution or internal SOC, leaving the organisation without 24/7 monitoring and threat detection capabilities. While Trend Micro's EDR provides some level of endpoint visibility, it is insufficient for detecting and responding to sophisticated threats in real time. The absence of an incident response retainer further exacerbates this gap, as the organisation is unprepared to respond effectively to active threats. This reactive posture leaves Acme Corp highly vulnerable to advanced persistent threats and ransomware attacks, which could have devastating consequences for the patient records database.
Business Impact & Risk	The lack of 24/7 monitoring and incident response capabilities creates a high likelihood of undetected threats compromising Acme Corp's critical systems. An attacker could exploit this gap to deploy ransomware or exfiltrate sensitive patient data, resulting in regulatory fines, reputational damage, and operational disruptions. The absence of a formal incident response capability means that recovery efforts would be delayed, potentially exceeding the stated RTO and causing significant financial losses.
Critical Gaps	• No 24/7 threat monitoring • Absence of incident response retainer
Zero-Cost Quick Wins	• Enable basic alerting and logging in Trend Micro EDR. • Set up email alerts for critical incidents. • Conduct regular reviews of security logs to identify anomalies.
Recommended Solutions	• Adlumin MDR
Strategic Remediation Rationale	Implementing Adlumin MDR will provide Acme Corp with 24/7 threat monitoring and response capabilities, addressing the critical gap of undetected threats. Adlumin's integration with existing tools will enhance visibility across endpoints, network, and cloud environments, enabling rapid detection and mitigation of active threats. This solution aligns with best practices for security operations and supports compliance with ISO 27001 by ensuring continuous monitoring and incident response readiness.
Partnership Recommendations	Planet IT will deploy and manage Adlumin MDR, providing 24/7 monitoring and threat response. Acme Corp will be responsible for ensuring that all endpoints and systems are integrated with the MDR solution.

Domain: Security Validation & Testing

Field	Details
Current Maturity	Pillar 2: Proactive Cybersecurity
Technical Analysis	Acme Corp conducts annual penetration tests and monthly authenticated vulnerability scans, which provide a baseline level of security validation. However, the testing cadence is insufficient given the dynamic threat landscape and the criticality of the patient records database. Annual penetration tests may not adequately identify emerging vulnerabilities or assess the effectiveness of recently implemented security measures. Additionally, the absence of continuous exposure management limits the organisation's ability to prioritise and remediate vulnerabilities in real time. While the current measures are a step in the right direction, they fall short of providing comprehensive security validation.
Business Impact & Risk	The limited testing cadence creates a gap in Acme Corp's ability to identify and remediate vulnerabilities in a timely manner. This increases the likelihood of adversaries exploiting unpatched vulnerabilities, leading to potential breaches of the patient records database. Such incidents would not only result in regulatory fines under GDPR but also damage client trust and operational continuity. The lack of continuous exposure management further exacerbates this risk, as vulnerabilities could remain unaddressed for extended periods.
Critical Gaps	• Insufficient penetration testing cadence • Lack of continuous exposure management
Zero-Cost Quick Wins	• Increase the frequency of vulnerability scans to weekly. • Conduct targeted penetration tests on high-risk assets. • Implement a process for prioritising and remediating vulnerabilities.
Recommended Solutions	• Sophos Managed Risk
Strategic Remediation Rationale	Sophos Managed Risk will provide continuous exposure management, enabling Acme Corp to identify and prioritise vulnerabilities in real time. By integrating with existing security tools, this solution will enhance the organisation's ability to remediate vulnerabilities before they can be exploited. This approach aligns with best practices for security validation and supports compliance with Cyber Essentials and ISO 27001.
Partnership Recommendations	Planet IT will deploy and manage Sophos Managed Risk, providing continuous exposure management and vulnerability prioritisation. Acme Corp will be responsible for remediating identified vulnerabilities and ensuring that all assets are included in the scope of the solution.

Domain: Governance, Risk & Compliance (GRC)

Field	Details
Current Maturity	Pillar 1: Reactive Cybersecurity
Technical Analysis	Acme Corp currently lacks a formal incident response plan and has no cyber insurance, leaving the organisation unprepared to manage and recover from security incidents. While the organisation conducts annual penetration tests and monthly vulnerability scans, these measures are not integrated into a broader governance framework, limiting their effectiveness. The absence of structured policies and procedures for incident response and risk management creates a reactive posture that is insufficient for meeting compliance requirements under ISO 27001 and Cyber Essentials.
Business Impact & Risk	The lack of a formal incident response plan and cyber insurance exposes Acme Corp to significant risks in the event of a security incident. Without a structured approach to managing incidents, the organisation is likely to experience prolonged downtime and increased recovery costs, potentially exceeding the stated RTO of 12-24 hours. Regulatory fines under GDPR and Cyber Essentials non-compliance could further compound financial losses, while reputational damage would undermine client trust and business continuity.
Critical Gaps	• No formal incident response plan • No cyber insurance
Zero-Cost Quick Wins	• Draft a basic incident response framework. • Identify key stakeholders for incident management. • Establish a process for documenting and reviewing incidents.
Recommended Solutions	• Planet IT IR/DR Planning Workshop
Strategic Remediation Rationale	The Planet IT IR/DR Planning Workshop will provide Acme Corp with a structured approach to developing an incident response plan. This will include defining roles and responsibilities, creating incident playbooks, and establishing a testing schedule, ensuring that the organisation is prepared to manage and recover from incidents effectively. This solution aligns with ISO 27001 requirements and supports compliance with Cyber Essentials.
Partnership Recommendations	Planet IT will facilitate the IR/DR Planning Workshop and provide templates and guidance for developing the incident response plan. Acme Corp will be responsible for implementing the plan and ensuring that all stakeholders are trained on their roles and responsibilities.

Domain: Operational Resilience & Backup

Field	Details
Current Maturity	Pillar 1: Reactive Cybersecurity

Technical Analysis	Acme Corp relies on on-premise backups for data protection, which are vulnerable to ransomware attacks and physical disasters. The absence of SaaS backups for M365 further exacerbates this risk, as critical data stored in the cloud is not adequately protected. This reactive approach to data resilience leaves the organisation susceptible to data loss, prolonged downtime, and regulatory non-compliance, particularly given the criticality of the patient records database. The lack of automated recovery testing means that the organisation cannot guarantee the integrity or availability of backups when they are most needed.
Business Impact & Risk	The reliance on on-premise backups and the absence of SaaS backups create a high likelihood of data loss in ransomware scenarios or physical disasters. The patient records database, a critical asset, could be rendered inaccessible, leading to operational disruptions that exceed the stated RTO of 12-24 hours. Regulatory fines under GDPR and loss of client trust would further magnify the financial and reputational impact. Without automated recovery testing, Acme Corp cannot ensure the reliability of its backups, increasing the risk of prolonged downtime and data loss.
Critical Gaps	• Reliance on on-premise backups • No SaaS backups for M365
Zero-Cost Quick Wins	• Enable basic retention policies for on-premise backups. • Perform manual recovery tests to validate backup integrity. • Implement access controls to secure backup data.
Recommended Solutions	• N-able Cove Data Protection
Strategic Remediation Rationale	Deploying N-able Cove Data Protection will address the critical gaps by providing a cloud-first backup solution with automated recovery testing. This will ensure that critical data, including the patient records database, is protected against ransomware and physical disasters. The solution's immutable backup capabilities align with best practices for data resilience and support compliance with GDPR and Cyber Essentials.
Partnership Recommendations	Planet IT will deploy and configure N-able Cove Data Protection to ensure automated backups and recovery testing. Acme Corp will be responsible for defining backup policies and ensuring that all critical data sources are included in the backup scope.

Domain: Supply Chain & Third-Party Risk

Field	Details
Current Maturity	Pillar 1: Reactive Cybersecurity
Technical Analysis	Acme Corp currently lacks a formal programme for assessing and managing supply chain and third-party risks. While the organisation relies on trusted vendors like Microsoft and Mimecast, there are no structured processes for evaluating their security postures or monitoring for potential risks. The absence of a Zero Trust

	approach in managing third-party access further exacerbates this gap, as it increases the likelihood of unauthorised access or data breaches originating from third-party connections. This reactive approach leaves the organisation vulnerable to supply chain attacks, which are increasingly being targeted by sophisticated threat actors.
Business Impact & Risk	The lack of a formal supply chain risk management programme exposes Acme Corp to significant risks from third-party vendors and partners. An attack on a third-party vendor could result in unauthorised access to Acme Corp's systems or data, including the patient records database. Such incidents would not only lead to regulatory fines under GDPR but also damage client trust and undermine the organisation's operational resilience. The absence of a Zero Trust approach further increases the risk of lateral movement within the network, amplifying potential damages.
Critical Gaps	• No formal supply chain risk management programme • Lack of Zero Trust approach for third-party access
Zero-Cost Quick Wins	• Require security assessments for all third-party vendors. • Restrict third-party access to specific systems. • Monitor third-party activity for anomalies.
Recommended Solutions	• Sophos ZTNA (Zero Trust Network Access)
Strategic Remediation Rationale	Implementing Sophos ZTNA will enable Acme Corp to adopt a Zero Trust approach for managing third-party access, significantly reducing the risk of unauthorised access or data breaches originating from supply chain connections. By enforcing identity-based access controls and monitoring third-party activity, this solution aligns with best practices for supply chain risk management and supports compliance with Cyber Essentials and ISO 27001.
Partnership Recommendations	Planet IT will deploy and configure Sophos ZTNA to manage third-party access securely. Acme Corp will be responsible for defining access policies and ensuring that all third-party vendors comply with security requirements.

Security Testing and Planning

Proactive Security Testing

Acme Corp should adopt a structured security validation programme over the next 12-18 months. This should include quarterly external penetration tests to identify and mitigate vulnerabilities exposed to the internet, as well as bi-annual internal assessments to validate internal defences. Web application and API testing aligned with development cycles is essential for securing customer-facing services. Continuous exposure management should be implemented using tools like Sophos Managed Risk to monitor and prioritise vulnerabilities. Additionally, breach-and-attack simulations aligned with the MITRE ATT&CK framework will help validate the effectiveness of defensive measures. Evidence from these activities should be documented and reviewed to inform ongoing security improvements.

Incident Response Planning

Acme Corp's incident response plan should define clear roles and responsibilities using a RACI matrix, ensuring accountability across IT, legal, and executive teams. A communications tree must be established to streamline stakeholder notification during incidents, including clients and regulatory bodies. Playbooks should be developed for high-probability scenarios such as ransomware infections and phishing attacks, detailing containment and recovery steps. Integrating Adlumin MDR will ensure 24/7 monitoring and rapid detection of active threats, while quarterly tabletop exercises will validate the plan's effectiveness and identify areas for improvement.

Disaster Recovery Planning

Acme Corp's disaster recovery strategy must prioritise the patient records database, aligning recovery time objectives (RTO) and recovery point objectives (RPO) to the stated 12-24 hour downtime tolerance. Immutable backups should be implemented using N-able Cove Data Protection to ensure data integrity and rapid recovery in ransomware scenarios. Failover procedures must be documented in detailed runbooks, with periodic testing to validate readiness. Annual disaster recovery exercises, including simulated ransomware attacks, will ensure that both technical and operational teams are prepared to execute recovery plans effectively.

Suggested Implementation Roadmap

At Planet IT we map our suggested and prospective implementation roadmaps to three distinct phases:

- **Foundational Hygiene:** Establishes the essential technical controls and baseline configuration practices required to eliminate common vulnerabilities and protect core corporate assets from opportunistic cyber threats.
- **Active Managed Defence:** Implements continuous security monitoring, real-time threat detection, and proactive incident response workflows to actively contest, isolate, and mitigate live attacks.
- **Adaptive Governance:** Integrates dynamic risk management, regulatory compliance, and continuous policy evolution to align security strategy with shifting business goals and the broader threat landscape.

These phases delineate the strategies required to implement a robust security, governance and compliance solution to effectively defend Acme Corp moving forward. The phases are made up as such:

Phase & Timeline	Primary Strategic Objective	Strategic Capability Overview
Phase 1: Foundational Hygiene (0-3 Months)	Stabilisation, perimeter hardening, and the elimination of baseline technical debt.	Establishing identity authentication enforcement, baseline network and endpoint hardening, fundamental data recoverability assurance, and initial risk visibility aligned to introductory compliance standards.
Phase 2: Active Managed Defence (3-9 Months)	Transitioning from passive protective tools to active, 24/7 threat hunting and validated defence.	Deploying continuous threat telemetry and incident response capabilities, offensive security validation, human risk mitigation programmes, and centralising security intelligence for broader framework alignment.
Phase 3: Adaptive Governance &	Driving the long tail of the roadmap to achieve sustainable enterprise	Implementing zero-trust architectural principles, automated incident orchestration and response workflows, behavioural

Resilience (10-18+ Months)	resilience, advanced automation, and board-level assurance.	anomaly detection, and proactive threat deception and hunting capabilities.
--------------------------------------	---	---

Please find below a bespoke roadmap of suggested improvements tailored for Acme Corp:

Partnership & Success Criteria

Planet IT offers both fully managed and co-managed cybersecurity services designed to align with Acme Corp's operational needs and compliance objectives. Under a fully managed model, Planet IT assumes end-to-end responsibility for deploying, configuring, and maintaining the security stack, ensuring continuous monitoring and policy enforcement. This model is ideal for organisations without dedicated internal resources for cybersecurity. In a co-managed arrangement, Planet IT collaborates closely with Acme Corp's internal IT team, providing expertise in areas like MDR integration, policy development, and incident response planning, while allowing Acme Corp to retain control over day-to-day IT operations. Both models include SLAs that guarantee 24/7 monitoring, rapid incident response, and periodic security reviews to adapt to emerging threats. More details can be found at <https://planet-it.example.com/partnerships/fully-managed> and <https://planet-it.example.com/partnerships/co-managed>.

Field	Details
Phase	Phase 1: Foundational Hygiene
Timeline	0-3 Months
Strategic Objective	Eliminate critical gaps in foundational security controls.
Key Deliverables	- Automated patch management via N-able N-central. - Universal MFA enforcement with Microsoft Entra ID. - Deployment of N-able Cove Data Protection for backups.
Estimated Effort	Moderate Effort / Operational Shift
Key Milestones	- Deploy N-able N-central to automate patching processes and reduce the attack surface. - Enforce MFA for all user accounts to mitigate credential theft risks. - Implement N-able Cove Data Protection to ensure data resilience and regulatory compliance.
Business Value Delivered	Addresses critical vulnerabilities, aligns with Cyber Essentials compliance, and stabilises the security environment.
Resource Requirements	Planet IT SOC, Internal IT Team

Field	Details
Phase	Phase 2: Active Managed Defence
Timeline	3-9 Months
Strategic Objective	Implement advanced threat detection and response capabilities.
Key Deliverables	• Deployment of Adlumin MDR for 24/7 threat monitoring. • Introduction of Sophos Managed Risk for continuous exposure management. • Security awareness training to reduce human risk factors.
Estimated Effort	High Effort / Transformational
Key Milestones	• Deploy Adlumin MDR to establish 24/7 threat monitoring and rapid response. • Implement Sophos Managed Risk to prioritise and remediate vulnerabilities. • Launch security awareness training to address phishing risks and improve user behaviour.
Business Value Delivered	Enhances threat detection and response capabilities, reducing the risk of undetected breaches.
Resource Requirements	Planet IT SOC, Internal IT Team

Field	Details
Phase	Phase 3: Adaptive Governance & Resilience
Timeline	10-18+ Months
Strategic Objective	Achieve long-term resilience through automation and adaptive governance.
Key Deliverables	• Deployment of Sophos ZTNA to replace legacy VPN. • Development of a formal incident response plan through Planet IT workshops. • Implementation of automated disaster recovery testing.

Estimated Effort	High Effort / Transformational
Key Milestones	• Replace legacy VPN with Sophos ZTNA to adopt a Zero Trust approach. • Develop and test a formal incident response plan to improve readiness. • Automate disaster recovery testing to ensure rapid recovery in ransomware scenarios.
Business Value Delivered	Establishes a resilient, adaptive security posture capable of withstanding advanced threats.
Resource Requirements	Planet IT SOC, Internal IT Team

Simulated attack of current infrastructure

Disclaimer: this is a fictional breach scenario leveraging threat intelligence and known threat actor activity mapped to the current technology stack and perceived security maturity of Acme Corp – this is meant as an illustration of potential risks only

Section 1: Threat Actor & Initial Access

In a hypothetical attack scenario targeting Acme Corp, the threat actor—a financially motivated ransomware group such as **LockBit 3.0**—could leverage a multi-stage intrusion strategy. Initial access may be gained through a **phishing campaign** designed to compromise credentials due to the absence of universal multi-factor authentication (MFA) enforcement. Once credentials are obtained, the attacker would likely pivot to exploit a known vulnerability in the VPN infrastructure, such as **[CVE-2018-13379]**(<https://nvd.nist.gov/vuln/detail/CVE-2018-13379>), which affects unpatched Fortinet FortiGate VPNs. This vulnerability allows unauthenticated attackers to retrieve sensitive system files, including credentials, enabling further compromise of the environment.

After gaining initial foothold, the attacker could escalate privileges by targeting unpatched vulnerabilities within the Trend Micro endpoint landscape or by abusing valid but compromised credentials. This activity aligns with **[MITRE ATT&CK T1078]**(<https://attack.mitre.org/techniques/T1078/>) (Valid Accounts) and **[T1068]**(<https://attack.mitre.org/techniques/T1068/>) (Exploitation for Privilege Escalation). The lack of an automated patching mechanism introduces significant risk, as it provides adversaries with a larger attack surface to exploit known vulnerabilities. The absence of immutable backups further incentivises ransomware deployment, as the attacker may anticipate a higher likelihood of ransom payment when recovery options are constrained.

Section 2: Attacker Progression

Once inside the environment, the attacker would likely perform reconnaissance to identify high-value assets, such as the Patient Records Database. Techniques such as

[T1083](<https://attack.mitre.org/techniques/T1083/>) (File and Directory Discovery) and [T1018](<https://attack.mitre.org/techniques/T1018/>) (Remote System Discovery) could be used to map the network and locate critical systems. The reliance on legacy VPN infrastructure with no Zero Trust principles would facilitate lateral movement, as the attacker could exploit overly permissive access once inside the network perimeter. Without conditional access policies, the environment lacks the necessary context-aware access controls to detect or prevent anomalous authentication attempts, further enabling the adversary to escalate their presence.

The attacker may then prepare for ransomware deployment by attempting to disable on-premise backups, leveraging [T1490](<https://attack.mitre.org/techniques/T1490/>) (Inhibit System Recovery). The absence of SaaS backups for Microsoft 365 and non-immutable backup solutions would leave Acme Corp highly vulnerable to data loss. By the time the adversary initiates the encryption phase, the environment's gaps in incident response readiness and lack of 24/7 monitoring would significantly delay detection, allowing the attack to progress unchecked.

Section 3: Sophos MDR Interception

In this scenario, Sophos MDR, powered by the **AI-Native Cyber Defense System**, would detect behavioural anomalies indicative of unauthorised lateral movement and privilege escalation. Specifically, the system's advanced telemetry integration across endpoint, network, and identity layers would identify suspicious activity such as abnormal authentication patterns (e.g., [T1078.001](<https://attack.mitre.org/techniques/T1078/001/>) - Privileged Account Abuse) and unauthorised access attempts to the Patient Records Database.

Upon detecting these behaviours, Sophos MDR would initiate a rapid containment response. Using **SOAR automation playbooks**, the compromised endpoints involved in the attack chain would be isolated from the network to prevent further lateral movement. Sophos MDR analysts would perform a root cause investigation, confirming the exploitation of the unpatched VPN vulnerability and the compromised credentials. The threat hunting team would neutralise the attacker's foothold by revoking the compromised credentials and deploying emergency patches to the affected systems. Additionally, Sophos MDR's **vendor-agnostic email monitoring (EMS)** would correlate phishing activity with the ongoing incident, providing critical context to the attack chain.

By leveraging the **Secureworks Counter Threat Unit's** thousands of additional threat detectors, the system would identify and terminate the ransomware payload before encryption could commence. The Patient Records Database, being the critical asset, would remain uncompromised due to the timely intervention of Sophos MDR, effectively neutralising the threat before it could reach its final objective. Post-incident, a formal **Root Cause Analysis (RCA)** would be conducted to detail the attack vector and recommend preventative measures.

Section 4: Recommended Solutions

To address the identified gaps and strengthen Acme Corp's cybersecurity posture, a transformative defence strategy must be implemented. Sophos MDR would be a foundational investment, providing 24/7 human-led threat hunting, rapid containment, and advanced behavioural detection across the entire attack surface. Its AI-native architecture ensures seamless integration of endpoint, network, email, and identity telemetry, enabling comprehensive visibility and response capabilities.

To mitigate vulnerabilities in the endpoint and server landscape, Sophos Intercept X with XDR should replace the existing Trend Micro solution. This would provide advanced exploit prevention, integrated detection and response capabilities, and automated patching mechanisms to close critical security gaps. For email and data protection, implementing immutable SaaS backups for Microsoft 365 using

a solution like **N-able Cove Data Protection** would ensure resilience against data loss from ransomware attacks.

Identity and access management must be strengthened through universal MFA enforcement and conditional access policies, which can be achieved by optimising Microsoft 365 Business Premium licensing. Additionally, replacing the legacy VPN with **Sophos ZTNA** would enforce Zero Trust principles, reducing the risk of unauthorised lateral movement.

To improve operational resilience, a formal incident response plan must be developed and tested through Planet IT-led workshops and tabletop exercises. Continuous exposure management, provided by **Sophos Managed Risk**, would ensure proactive identification and remediation of vulnerabilities. Finally, acquiring cyber insurance would provide financial protection against future incidents, aligning operational risk management with industry best practices.

Why Planet IT

Planet IT is a leading IT company offering complete outsourced IT solutions to organisations across the UK and Europe. Based in Milton Park, Oxford, we provide comprehensive support services to suit your needs and deliver business transformation.

Our expert team has an extensive record of delivering software and hardware solutions to major blue-chip clients. Our technicians are highly skilled in planning, implementing and troubleshooting.

At Planet IT, we always take time to assess your IT needs and existing infrastructure, make recommendations, and implement improvements quickly and efficiently. In addition, we are highly experienced in planning and installing entire new IT systems in large organisations.

Commented [JD1]: @Barry O'Brien do we have one of these with updated vendor logos?



**OUTSOURCED
IT SUPPORT**



**4th LINE
IT SUPPORT**



**IT PROJECT
ENGINEERS**

**IT HARDWARE
& SOFTWARE
PROCUREMENT**



**IT SECURITY
EXPERTS**



**BACK-UP & DR
SPECIALISTS**



**PHONE
SYSTEMS**



**INTERNET
CONNECTIVITY**

**Microsoft
Partner**

Gold Cloud Platform
Gold Small and Midmarket Cloud Solutions
Silver Cloud Productivity
Silver Collaboration and Content
Silver Application Development



veeam



Microsoft Azure



mimecast

censornet



kaspersky

smoothwall

FORTINET



QNAP



vmware

www.Planet-IT.net

Our Pedigree

Since we started in 2003, Planet IT has supported over 2,000 clients in the UK, US and Europe. We are trusted by businesses across multiple industries, delivering various projects across Security, Backup & Disaster Recovery, Cloud migration, Fully Managed Support, Device as a Service and software licencing.

Since the beginning, we have built our business on first-class customer service and employing the best people available. We continue that ethos today, constantly building and maintaining our client relationships. Here's a snapshot of some of the customers we work with today.

Commented [JD2]: Do we want to change any of these @Barry O'Brien

Commented [BO2R2]: I just added a couple but not going to remove any @James Dell



Assumptions and Client Responsibilities

This agreement is between;
 A. [Acme Corp] ("The Client")
 B. Planet IT ("The Provider")

Project Assumptions

This Statement of Work is offered by Planet IT based on the assumptions outlined below:

- The project will be delivered using the resources outlined within the document. Any delays to the project caused by The Client will result in additional days required to complete the project, these additional days will be at cost to The Client.
- Should the scale of the project transpire to be greater than initially expected, The Client are responsible for any additional time required to complete the project.
- The project will be delivered without interruption or suspension by The Client.
- Tasks assigned to The Client resources as part of detailed resource planning will be completed on time.
- Information and documentation requested by Planet IT for this project will be accurate, complete and provided in soft copy within two days.
- Reasonable requests from Planet IT to The Client for functional or technical clarification will be responded to within one business day. Failure to respond during the allocated time frame could have an impact on timelines and associated cost.
- The Client accepts that Planet IT's professional services team members will perform their duties through a combination of on-site and off-site activity.
- The Client accepts non-exclusive access to the Planet IT's professional services team members during the project.
- Planet IT documentation deliverables will be provided in editable formats such as Microsoft Word or Excel as applicable.
- Where applicable installation and/or configuration of The Client owned application software will be the responsibility of The Client.
- Any representatives of The Client (or their associates) that are involved at the various steps in the project are available as planned, adequately skilled and competent to execute the tasks required of them.
- Any The Client nominated decision-making representative is duly empowered.
- Planet IT will receive a minimum of five working days' notice of any rescheduling of work resulting from delays caused by The Client, or their contractors.
- The Client will provide single point of contact for all aspects relating to project delivery.
- Network connectivity IP addresses and naming conventions will be provided by The Client where applicable.
- Business hours are standard UK business hours, 7.5 hour working day.
- The project will operate as a gated system. The project will be placed on hold and resources suspended until gate controls are met.
- The Client will be responsible for undertaking any appropriate user acceptance testing and sign off as accepted based on the outlined test schedule.
- If The Client opts out of user acceptance testing, Planet IT will not assume accountability for any project failures. It is the responsibility of The Client to address any necessary remediation work.

Client Responsibilities

These following items are responsibilities that The Client needs to fulfil as part of the project:

- Documentation/deliverables provided as part of the project will go through a maximum of two The Client reviews unless mutually agreed.
- In order to avoid delays to the project, The Client must review the documentation/deliverables within two business days of receipt of the document, except where mutually agreed.
- The Client is responsible for the supply of all infrastructure (hardware, software licences, network and environments) requirements to successfully deliver the project.
- The Client will be responsible for all aspects of data quality, availability, backups and restores required to successfully deliver the project.
- The Client will be responsible for raising all necessary change control requests.
- The Client will provide site access and a suitable work area to the project team.
- The Client will provide internal staff as per the schedule or as reasonably required including, but not limited to:
 - Project Manager to liaise with Planet IT Technical Design Authority to assist with scheduling The Client deliverables, resources and activity as per the agreed schedule.
 - Availability of appropriate The Client representatives at necessary requirements, design and planning workshops, testing and validation activities.
 - Provide access to network information, diagrams, site floor plans or site assistance, indicating outlet location, station number, username, and station type for each site where applicable.
 - Third party vendor coordination excluded from the scope of this proposal unless directly included in scope.
 - Supplying third party resources to assist in interfacing with third party equipment.
 - The successful execution and completion of User Acceptance Testing.
- The Client will inform Planet IT of any health and safety requirements.
- Ensure that Planet IT personnel who attend The Client site are instructed on all relevant health and safety regulations and criteria.
- Ensuring all dependencies that this engagement may have on other The Client projects is planned and met.
- The Client is to provide a minimum of ten working days' notice prior to agreed resource schedule commencement.
- The Client cannot cancel planned activities on this schedule during the three working days prior to starting those activities. If so, The Client will incur the full cost of the cancelled activities during that three-day period.

Authors

Name	Role
Jane Doe	Technical Architect
[AM NAME]	Account Manager
Justin Towle	Head of Professional Services
Mike Bellido	Technical Architecture Director
Nick Johns	Chief Technical Officer
Adrian Sweeney	Chief Commercial Officer

Planet IT Contact Details

Method	Details	Method	Details
Telephone	01235 433900	Fax	+44 (0) 1235 433901
Email	architecture@planet-it.net	Address	Planet IT Ltd 85f Park Drive Milton Park Abingdon Oxfordshire OX14 4RY

Revision Details

Revision	Date	Author	Comments
1.1	28/03/2025	J.Dell / A.Sweeney / J.Towle / R. McClafferty	Updated for 2025
2.0		Jane Doe	
2.1		[APPROVER NAME]	Internal Approval

Distribution List

Name	Company
	Acme Corp

Disclaimer

Whilst every precaution has been taken in the preparation of this document, no responsibility is assumed for errors or omissions, nor is any liability assumed for loss or damage resulting from the use of the information it contains, to the extent such error or omission is a result of any information, data or documents provided to Planet IT by the Customer and relied on by Planet IT in the preparation of this document.



01235 433 900



85F Park Drive
Milton Park
Abingdon
OX14 4RY



enquiries@planet-it.net

www.planet-it.net

Terms and Conditions

Confidentiality

All information within this document is given in the strictest confidence and is considered as Confidential Information and genuine commercially sensitive information. With regards to this all parties shall treat information detailed in the strictest confidence and shall not, without the prior consent of the other party, disclose any information with regards to this proposal to any other organisations, whosoever they may be. In the event the customer is compelled by law or by any applicable regulatory agency (including a request to disclose information in accordance with the Freedom of Information Act 2000) to disclose any Confidential Information the customer shall immediately consult with Planet IT Limited prior to any such pending disclosure so that the parties may discuss whether the Confidential Information is exempt from disclosure or so that a protective order or other appropriate remedy may be obtained. If such an order or other remedy is not available, the customer shall disclose only that minimum portion of Confidential Information that it is legally compelled to disclose, consistent with the advice of its counsel.

Disclaimer

Planet IT Limited makes no representations or warranties with respect to the contents or use of this document, and specifically disclaims any express or implied warranties of merchantability or fitness for any purpose.

Intellectual Property

Nothing in this document is intended to grant any rights under any patent, copyright or other intellectual property right of Planet IT Limited.